

[GRC RISK REGISTER]

GRC Risk Register

Cybersecurity Risk Management System

Academic Project Report

A lightweight, standalone, and deterministic qualitative cybersecurity risk management application designed to register organizational assets, assess cybersecurity threat scenarios using a standardized 3x3 risk matrix, track risk treatment lifecycle progression, and generate executive reporting.

Course / Domain:	Cybersecurity & Information Security / GRC
Project Category:	Cybersecurity Governance, Risk & Compliance (GRC)
Author / Student:	Tanvi Mishra
Supervisor / Evaluator:	Department of Computer Science & Cybersecurity
Implementation Stack:	Python 3 Standard Library, SQLite 3, Vanilla JS/HTML5/CSS3
Verification Status:	32 / 32 Automated Unit & Integration Tests Passed (100%)
Date:	August 2026

1. Introduction

Modern organizations rely heavily on diverse digital resources, including databases, web portals, network routers, and cloud services. Managing these assets requires a structured approach to identifying vulnerabilities, evaluating likelihood and impact, and tracking remediation actions. The **GRC Risk Register** provides an accessible web application designed to manage cybersecurity risks in a transparent and structured manner. Cybersecurity Risk Management is a core discipline within Governance, Risk, and Compliance (GRC), providing security analysts with a standardized method to prioritize security investments and ensure accountability across all stages of risk treatment.

2. Problem Statement

Small organizations and academic laboratories often struggle with managing cybersecurity threats effectively due to several common challenges:

- **Unstructured Record-Keeping:** Organizations often track risks in static spreadsheets that suffer from version conflicts, accidental data overwrites, and poor consistency.
- **Disconnected Asset Context:** Cybersecurity threats are frequently assessed in isolation without linking them to specific digital assets, making it hard to prioritize critical systems.
- **Subjective Risk Scoring:** Without a deterministic calculation model, different analysts assign inconsistent risk ratings to similar threat scenarios.
- **Lack of Lifecycle Tracking:** Identified risks are often logged once and forgotten, lacking clear status progression (Open → In Progress → Treated → Closed).
- **Absence of Access Control:** Basic spreadsheets cannot enforce least-privilege user access or maintain an immutable audit trail of changes.

3. Project Objectives

The project provides a complete, accessible, and mathematically sound Cybersecurity Risk Management System accomplishing six key objectives:

Register Assets	Maintain a unified inventory of assets categorized into Data, System, Device, and Service with importance ratings.
Identify Risks	Record cybersecurity threat scenarios linked directly to affected assets with descriptive consequences.
Deterministic Scoring	Implement a reproducible 3x3 qualitative risk calculation model based on Likelihood (1-3) and Impact (1-3).
Lifecycle Tracking	Track risk remediation status across four distinct operational phases with notes and ownership.
Interactive Visibility	Provide an executive dashboard with summary KPIs, an interactive 3x3 matrix heatmap, and severity breakdowns.
Exportable Reporting	Generate formatted printable summary reports and downloadable CSV datasets for executive review.
Access Control & Audit	Enforce role-based access control (RBAC), salted password hashing, and server-side immutable audit logging.

4. Main Application Features

The application provides a comprehensive suite of risk management tools accessible through a clean, single-page web interface:

Feature	Description & Operational Capability
Authentication	Secure login view with session token issuance, PBKDF2 password verification, and instant session termination on logout.
Executive Dashboard	Centralized management overview displaying top KPI summary metrics, interactive 3x3 risk matrix heatmap, and severity progress bars.
Asset Management	Asset inventory register with automatic ID generation (AST-001), categorization, criticality ratings, and safe soft-archiving.
Risk Register	Threat scenario register linking risks to assets, capturing consequences, computing scores, and tracking treatment progression.
Risk Scoring Engine	Deterministic qualitative calculation algorithm multiplying Likelihood (1-3) by Impact (1-3) to yield Low, Medium, or High classification.
Interactive Matrix	Visual 3x3 risk matrix grid dynamically showing risk counts per cell with interactive filtering into the risk register.
Status Lifecycle	Four-phase remediation workflow (Open → In Progress → Treated → Closed) ensuring clear ownership and audit trail.
Printable Reports	Clean in-browser executive risk summary report with browser-native printing styles and summary statistics.
CSV Data Export	One-click RFC-4180 compliant CSV export generating full dataset downloads for external analysis and archiving.
Audit Trail	Immutable server-side audit logger recording all creation, modification, and archiving events with timestamps and usernames.
Feature Controls	Administrator-managed granular capability controls (29 toggleable operations across 6 categories) stored in SQLite.

All features operate as a coherent Single-Page Application (SPA) where asynchronous fetch calls update table rows, KPI numbers, and charts without triggering full-page browser refreshes.

5. How Risk Scoring Works

Risk scoring in the application uses a transparent, deterministic mathematical model adhering to standard qualitative risk assessment guidelines (such as NIST SP 800-30). Rather than relying on arbitrary numbers, the system computes the risk score using two discrete variables:

$$\text{Risk Score} = \text{Likelihood (1-3)} \times \text{Impact (1-3)}$$

Rating Scale Definitions:

- **Likelihood (1-3):** 1 = Low (Unlikely / rare occurrence), 2 = Medium (Moderate / possible occurrence), 3 = High (Frequent / highly probable occurrence).
- **Impact (1-3):** 1 = Low (Minor operational inconvenience, negligible data loss), 2 = Medium (Moderate service degradation, limited compliance exposure), 3 = High (Catastrophic breach, severe downtime, high financial/legal impact).
- **Score Severity Classification:**
 - **Low Severity (Score 1-2):** Acceptable risk level; routine monitoring required.
 - **Medium Severity (Score 3-4):** Moderate risk level; remediation plan should be scheduled.
 - **High Severity (Score 6-9):** Critical risk level; immediate security mitigation required.

The 3 × 3 Qualitative Risk Matrix:

Likelihood \ Impact	Low (1)	Medium (2)	High (3)
High (3)	Score 3 Medium	Score 6 High	Score 9 High
Medium (2)	Score 2 Low	Score 4 Medium	Score 6 High
Low (1)	Score 1 Low	Score 2 Low	Score 3 Medium

6. System Architecture

The GRC Risk Register is structured as a clean four-tier architecture requiring zero external runtime frameworks:

Layer	Technology	Responsibilities
Presentation Tier	Web Browser	Renders user interface, captures form inputs, handles client-side event routing, and manages local session storage.
Frontend Client	Vanilla HTML5, CSS3, JavaScript (ES6+)	Single-Page Application managing asynchronous REST API calls, modal calculation previews, and tab navigation.
Backend Server	Python Standard Library (http.server)	Routes REST API requests, authenticates Bearer tokens, enforces server-side RBAC, validates payloads, and calculates risk scores.
Persistence Tier	SQLite 3 Embedded Database (sqlite3)	Stores relational data in ACID-compliant tables (users, assets, risks, feature_controls, audit_logs).

7. Database Design & Entity Schema

The relational SQLite schema maintains referential integrity. Passwords are never stored in plaintext.

Table Entity	Key Columns Stored	Purpose & Security Controls
users	id, username, password_hash, salt, full_name, email, role, active	Stores user accounts. Passwords saved only as salted cryptographic hashes (PBKDF2-HMAC-SHA256).
assets	id, asset_id, name, type, importance, owner, description, active	Stores organizational assets. Uses soft-delete (active=0) for safe archiving.
risks	id, risk_id, title, description, consequence, asset_id, likelihood, impact, score, level, status, owner, notes, active	Stores evaluated threat scenarios linked to assets via foreign key (asset_id). Stores calculated score and level.
feature_controls	id, feature_key, label, category, description, is_enabled_for_demo	Persists 29 granular operational feature availability toggles across 6 categories.
audit_logs	id, timestamp, user_id, username, action, entity_type, entity_id, details	Immutable audit trail recording all system creation, modification, and archiving events.

8. Security Mechanisms

The application incorporates standard cybersecurity best practices to ensure authentication, authorization, and data integrity:

- **Password Hashing:** Passwords protected using PBKDF2-HMAC-SHA256 with 100,000 iterations and unique 16-byte random salts per user.
- **Session Token Handling:** Cryptographically random 32-byte hexadecimal session tokens transmitted via HTTP Authorization Bearer headers.
- **Role-Based Access Control (RBAC):** Server enforces role separation between Administrators, Risk Analysts, and Demo accounts.
- **Server-Side Authorization:** UI restrictions mirrored by strict server-side validation returning HTTP 403 Forbidden on protected mutation routes.
- **Input Validation:** JSON payloads validated for field presence, data types, and numeric range bounds (1-3) prior to database execution.
- **Immutable Audit Trail:** All critical modifications (creation, editing, archiving, feature updates) write permanent records to the audit log.

9. End-to-End User Workflow

The step-by-step workflow illustrates how an analyst uses the application to register an asset, assess a threat, and track remediation:

Step	User Action	System Response & State
1. Login	User enters credentials on login view.	Server verifies password hash, generates session token, and loads user profile.
2. Asset Inventory	User navigates to Assets tab and adds an asset.	System assigns auto-increment ID (e.g. AST-001) and stores asset record.
3. Risk Identification	User clicks '+ Add Risk' and selects asset.	Form opens with asset linkage, threat title, and consequence inputs.
4. Scoring Preview	User selects Likelihood (1-3) and Impact (1-3).	Real-time preview dynamically calculates Score ($L \times I$) and badge (Low/Med/High).
5. Treatment Tracking	User updates status to In Progress or Treated.	Database records status transition, owner, notes, and writes an audit event.
6. Executive Review	User opens Dashboard tab.	Dashboard updates KPI counters, 3x3 heatmap cell counts, and severity progress bars.
7. Report Generation	User clicks 'Print Report' or 'Export CSV'.	Application formats printable executive summary or downloads RFC-4180 CSV dataset.

10. Testing & Verification

The application has been verified through an automated test suite and live end-to-end integration audits. All test cases are fully reproducible using the test runner (`python run_tests.py`).

TOTAL AUTOMATED TESTS 32	FAILURES / ERRORS 0 / 0	PASS RATE 100%	EXECUTION TIME < 2.5s
-----------------------------	----------------------------	-------------------	--------------------------

Breakdown of Automated Test Modules:

Test Module	Test Scope & Verification Objectives	Tests	Result
test_calculator.py	Verifies all 9 Cartesian coordinate pairs of Likelihood (1-3) × Impact (1-3), score bounds, and invalid type rejection.	6	PASSED
test_auth.py	Verifies PBKDF2-HMAC-SHA256 hashing, salt uniqueness, session lifecycle, token expiration, and revocation.	3	PASSED
test_assets.py	Verifies asset creation, AST-xxx auto-numbering, type validation, soft archiving, and restore capabilities.	4	PASSED
test_risks.py	Verifies risk creation, score auto-calculation, foreign key asset validation, status progression, and recalculation on update.	5	PASSED
test_api.py	Verifies end-to-end REST API HTTP endpoints: login authentication, 401 unauthenticated guards, and 403 RBAC privilege enforcement.	4	PASSED
test_feature_controls.py	Verifies 29 granular feature controls in SQLite, dynamic Admin updates, Demo 403 mutation guards, and clean login view.	8	PASSED
test_rebranding.py	Scans application source code to ensure zero forbidden legacy vendor terms and consistent project identity.	2	PASSED

Live Server Verification Suite:

A live verification suite (`verify_chg0010.py`) executed against port 8000 confirmed: (1) development notice banner presence, (2) zero forbidden account-restriction phrases in source code, (3) neutral 403 Forbidden messages for restricted demo actions, (4) full unrestricted Admin access, and (5) 100% real SQLite data delivery with zero fabricated metrics.

11. Application User Interface Overview

The following screenshots illustrate the flat Material design system, intuitive layouts, and responsive components implemented in the application.

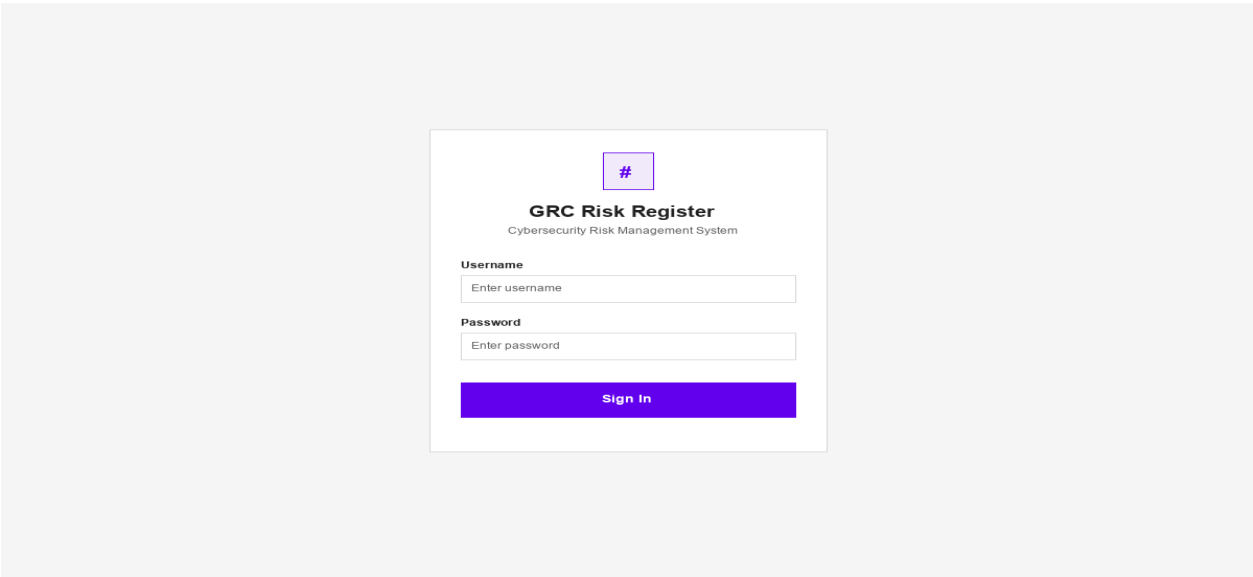


Figure 1: Unauthenticated Login Screen with clean input fields and zero exposed credentials.

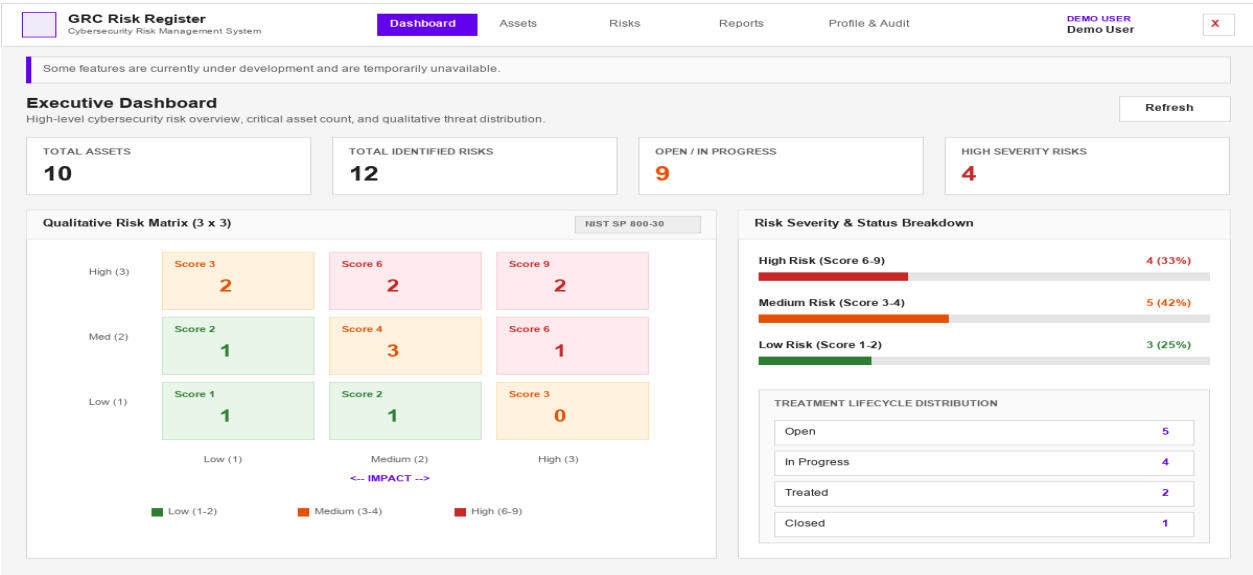


Figure 2: Executive Dashboard showing 4 KPI summary cards, interactive 3x3 Risk Matrix Heatmap, and severity breakdown.

11. Application User Interface Overview (Cont.)

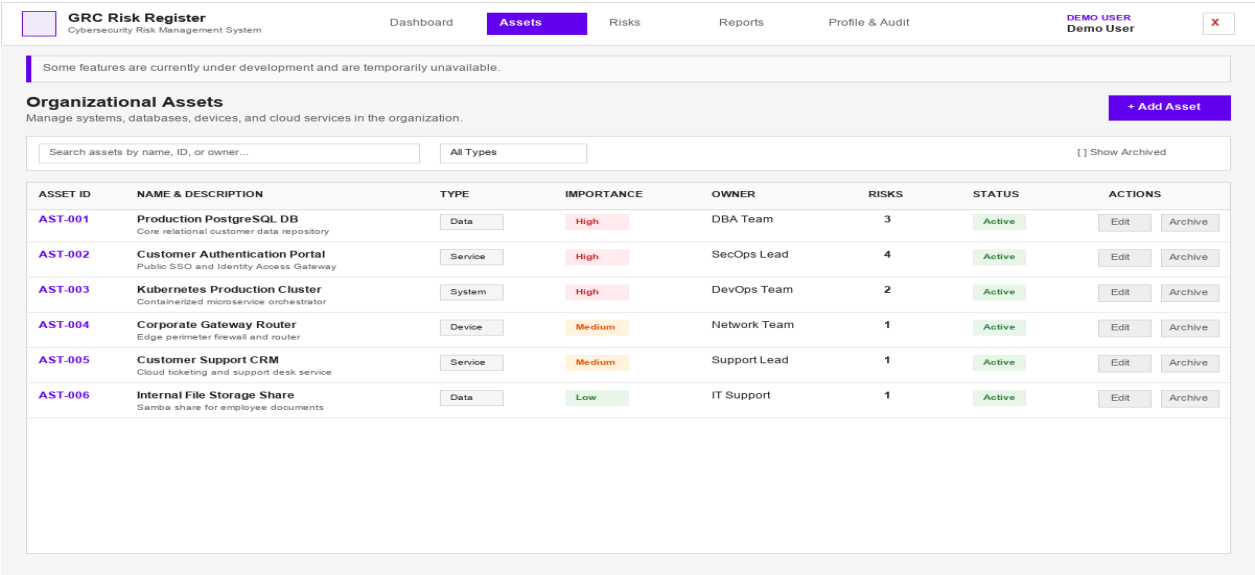


Figure 3: Organizational Asset Register showing asset inventory, categorization, and importance ratings.

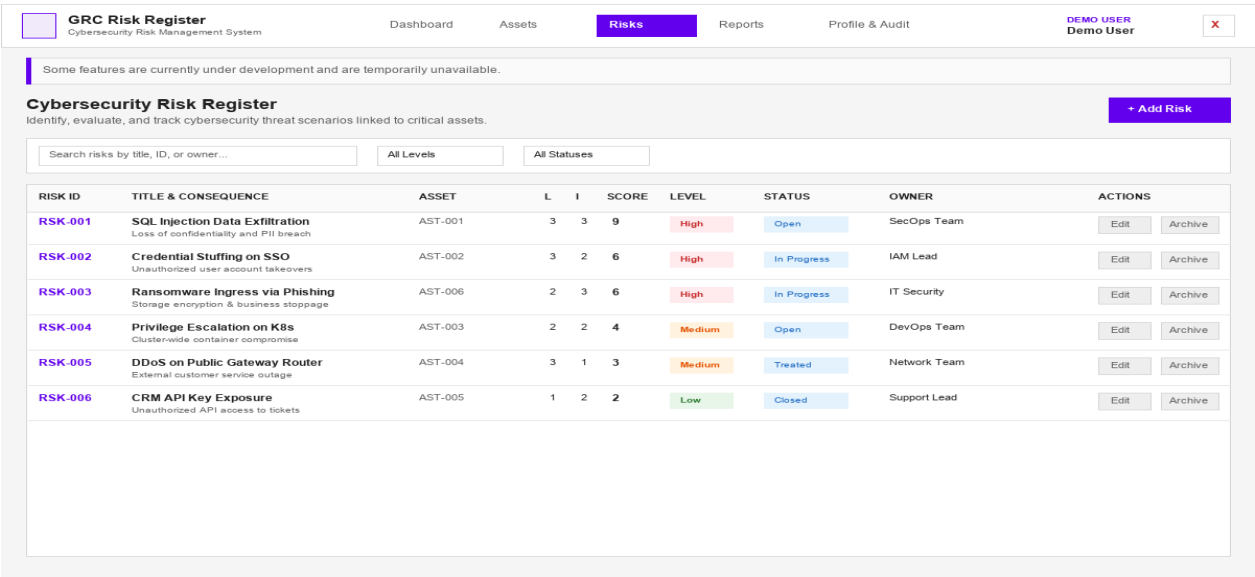


Figure 4: Cybersecurity Risk Register showing threat scenarios, Likelihood, Impact, calculated score, and lifecycle status.

11. Application User Interface Overview (Cont.)

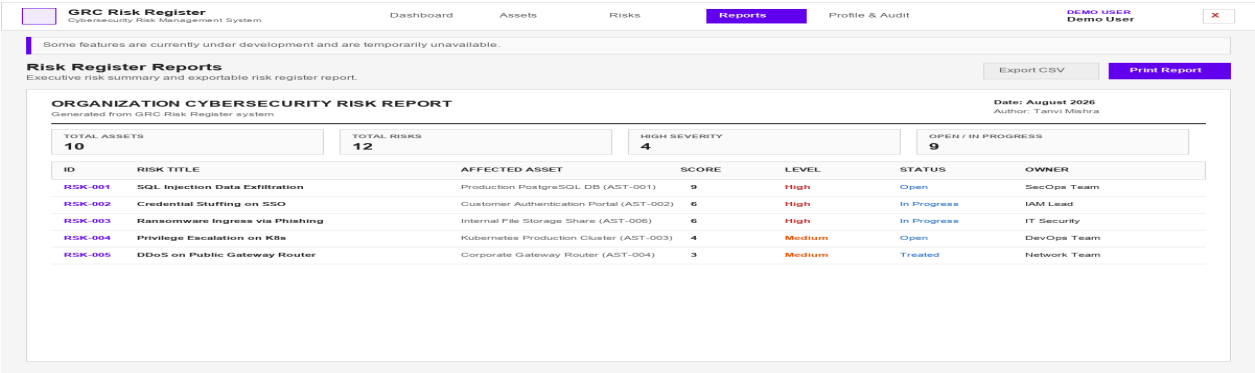


Figure 5: Executive Risk Report View formatted for browser-native printing and CSV export.

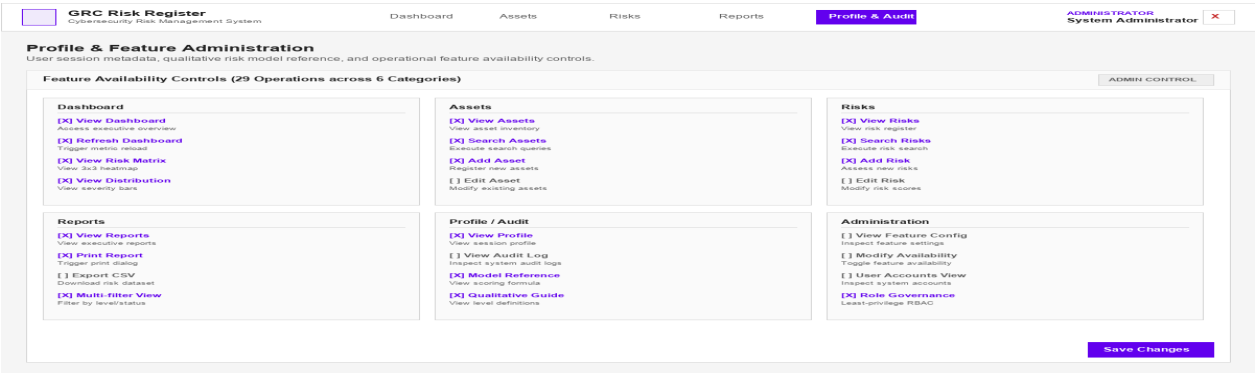


Figure 6: Administrator Feature Governance View displaying 29 operational controls across 6 categories.

12. Conclusion

The **GRC Risk Register** project demonstrates a fully functional, self-contained Cybersecurity Risk Management System. By implementing a lightweight Single-Page Application coupled with a Python Standard Library backend and SQLite persistence, the project achieves zero-dependency portability and rapid execution. The system successfully replaces spreadsheets with a structured relational model, deterministic 3x3 risk scoring, lifecycle status tracking, and role-based access governance.

13. Future Improvements

- **Granular Risk Evaluation:** Expanding risk assessment criteria to include specific threat actor taxonomies and vulnerability categories.
- **Enhanced Reporting & Filtering:** Adding customizable multi-parameter PDF generation and automated scheduled email reports.
- **Expanded Input Validation:** Introducing stricter business validation rules and bulk asset/risk import capabilities via spreadsheet uploads.
- **Additional Security Controls:** Implementing multi-factor authentication (MFA) and granular row-level data access permissions.
- **Automated Database Maintenance:** Adding built-in automated SQLite database backup, restore, and integrity verification utilities.